

AI Governance Control Model

Executive Brief for CISO, Compliance, Risk, and AI Governance Leaders

Governance Challenge

Enterprise AI governance fails when policy exists only as documentation and is not enforced at the point of decision. A written policy can define expected behavior, but it does not prove that a specific AI-assisted action was authorized, reviewed, traceable, or blocked when evidence was missing.

The control challenge is to connect policy, human oversight, provenance, and audit evidence to runtime execution. Without that connection, governance remains dependent on manual review, after-the-fact interpretation, and incomplete operational logs.

Control Model

A practical AI governance control model should evaluate five control areas before execution: policy validation, human oversight, provenance, audit evidence, and fail-closed enforcement.

Each control area must produce evidence. If evidence is incomplete, unverifiable, stale, or inconsistent with policy, the action should be denied and the denial should be recorded. This creates a defensible control path rather than an assumed governance posture.

Decision Flow

The decision flow begins with policy validation. The system determines which policy version applies to the proposed AI-assisted action and whether the action falls within an approved operating scope.

The flow then checks human oversight requirements, provenance, and audit evidence. If all required controls are satisfied, execution may proceed. If any required control is missing or fails validation, execution is blocked and the control failure is recorded.

Required Evidence

Policy Validation	
Evidence	Applicable policy version, scope assessment, validation result, and decision reason.
Human Oversight	
Evidence	Reviewer identity, approval or denial decision, timestamp, approval scope, and policy context.
Audit Evidence	
Evidence	Actor, control checks performed, evidence state, execution outcome, and denial reason where applicable.
Provenance	
Evidence	Input lineage, workflow context, model or automation context, source references, and evidence references.
Fail-Closed Enforcement	
Evidence	Blocked outcome, missing-control indicator, denial timestamp, and preserved audit trail.

Fail-Closed Conditions

- Required human approval is missing, expired, unverifiable, or outside the permitted approval scope.

- The applicable policy version cannot be determined or the proposed action falls outside policy scope.
- Provenance is incomplete, inconsistent, or cannot be tied to the action being executed.
- Audit evidence cannot be generated, persisted, or linked to the runtime decision.
- Trust state, reviewer authority, or validation freshness cannot be verified at the time of execution.

Enterprise Outcomes

- High-risk AI actions are subject to explicit control checks before execution.
- Security, compliance, legal, risk, and audit teams can reconstruct allow and deny decisions.
- Human oversight becomes evidence-producing rather than informal or implied.
- Provenance and policy validation are tied to the runtime decision path.
- Unknown state is treated as unsafe state, preserving fail-closed behavior.